ACCESS-CONTROL-MODELS-LDAP

접근 통제 정책·보안모델·LDAP

연관 기출 · 127-2-6, 129-2-2, 133-4-3

한눈에 이해

로그인에 성공한 사람에게도 업무·등급·속성에 따라 열람이나 수정 권한을 따로 부여합니다.

정의와 핵심 원리

접근 통제는 주체가 객체에 대해 수행하려는 행위를 정책과 조건에 따라 허용하거나 거부하는 기능입니다. 식별·인증 → 인가 결정 → 정책 집행 → 감사 순으로 설명하고, 보안 모델마다 보호하려는 목표를 구분합니다.

• DAC는 소유자의 재량, MAC는 중앙에서 정한 등급과 레이블, RBAC는 역할과 권한, ABAC는 주체·객체·행위·환경의 속성과 정책을 기준으로 접근을 결정합니다. 최소 권한, 직무 분리, 기본 거부, 정기적인 권한 회수를 적용하고 정책 결정과 집행을 구분합니다.

• BLP는 기밀성을 위해 상위 등급 읽기와 하위 등급 쓰기를 금지합니다. 엄격한 Biba 모델은 무결성을 위해 하위 등급 읽기와 상위 등급 쓰기를 금지합니다. Clark-Wilson은 인증된 변환 절차, 무결성 검증, 제약 자료와 직무 분리로 업무 데이터의 무결성을 관리합니다.

• LDAP는 디렉터리 접근 프로토콜입니다. TLS로 서버를 검증한 뒤 필요할 경우 서비스 계정으로 사용자 DN을 검색합니다. 찾은 DN으로 사용자 Bind를 수행한 뒤 권한 속성을 조회해 인가를 결정할 수 있습니다. Simple Bind에 비밀번호를 쓰면 전송을 보호하고, 익명 또는 비인증 Bind 성공을 사용자 인증 성공으로 해석하지 않도록 주의합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
BLP	기밀성: 상위 등급 읽기·하위 등급 쓰기 금지	낮은 등급으로 비밀이 새는 것을 방지
Biba	무결성: 하위 등급 읽기·상위 등급 쓰기 금지	오염된 정보의 전파 방지
Clark-Wilson	정당한 거래·직무 분리	승인 변환 절차와 감사

적용 예제

급여 수정 권한

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 급여를 수정하는 사람, 승인하는 사람, 감사하는 사람을 구분합니다.

1. 입력자는 초안만 수정합니다. 승인자는 자신이 작성한 초안을 승인할 수 없습니다.
2. 승인 절차를 통과한 변경만 지정된 API로 급여 자료에 반영합니다.
3. 무결성 검사와 감사 로그로 이상 변경을 확인합니다.
4. 사용자 인증과 급여 수정 권한을 각각 확인합니다.

결과·해석: 역할과 절차를 나누면 한 사람이 급여를 수정하고 승인하는 일을 막을 수 있습니다. 감사 로그로 누가 무엇을 변경했는지 확인합니다.

전제·주의: LDAP와 ABAC 공식 자료를 확인했습니다. BLP·Biba·Clark-Wilson의 원논문 전문은 확인이 남아 있습니다.

답안 골격과 혼동 방지

정의와 절차 → DAC·MAC·RBAC·ABAC → 세 보안 모델 → LDAP 인증·인가 흐름 → 정책 집행과 감사

- 인증은 주체를 확인하고, 인가는 그 주체의 행위를 허용할지 결정합니다.
- BLP와 Biba 읽기 방향을 혼동하지 않습니다.

내용을 가리고 회상

1. BLP가 하위 등급 쓰기를 막는 이유는 무엇입니까?
2. ABAC의 환경 속성을 하나 예로 들어 보십시오.
3. LDAP Bind에 성공하면 급여 수정 권한도 부여됩니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- RFC4513: LDAP Authentication Methods - R. Harrison / IETF; 2006-06; 확인 2026-11-05.
- NIST SP800-162: ABAC Definition and Considerations - NIST; 2014;2019갱신; 확인 2026-11-05.